PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Opération REACTIV : Point de situation ANSSI

03-760 ANSSI - REACTIV point de situation septembre 2026 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'ANSSI pilote l'opération REACTIV pour traiter les compromissions de comptes et les violations de données sous l'autorité du Premier ministre.
2. La vulnérabilité Metabase CVE-2026-72898 a permis l'exfiltration de données dans neuf instances ministérielles via une injection SQL.
3. L'analyse forensique et la remédiation sont des piliers de l'intervention pour établir l'origine des incidents et reprendre le contrôle des systèmes.

Présentation de l'opération REACTIV

Notion	À retenir
Origine de l'opération	Demande du **Premier ministre** le **1er septembre 2026** (attaques cybercriminelles, violations de données de l'État). Point de situation **CERTFR-2026-CTI-006**, évolutif et non exhaustif.
Contenu de l'opération	**REACTIV** (**REponse et ACTion Interministérielle face aux Violations de données**) : basculement des efforts de l'ANSSI pour traiter compromissions de comptes et violations de données.
Autorité de l'ANSSI	L'ANSSI peut **faire prendre** aux ministères, dans des **délais contraints**, les **mesures d'urgence** pour protéger les données des citoyens.

Impacts et travaux de l'ANSSI

Notion	À retenir
Volumes exposés	Fiscal : **353 000** particuliers, **252 000** pros, **434 000** propriétaires (cadastre). Contact : AEFE (**> 30 000** en synthèse, **> 300 000** dans le détail), SNU **275 000**, Bloctel **3 millions** de numéros, Préférence Formation **5 265**.
Autres données	Identifiants fiscaux, SIREN/SIRET, certifications, **journaux de connexion**, **mots de passe hachés**, échanges **Tchap**, courriels.
Travaux de l'ANSSI	Coordination technique, partage de **marqueurs d'attaque**, appui **forensique** et **remédiation**. Diffusion alerte **Metabase** `CVE-2026-72898` et durcissement des **authentifications**.

Synthèse des tendances et vulnérabilités

Notion	À retenir
Chiffres clés	Depuis le **1er août 2026** : **99** violations portées à l'ANSSI, **67** confirmées, dont **32** en cours de traitement par l'ANSSI.
Metabase CVE-2026-72898	Injection SQL permettant l'accès à la base de données et les droits **administrateur** sans authentification. **9** instances ministérielles compromises. Correctif disponible le **6 août 2026**.
Infostealers	Vol d'identifiants sur **postes personnels** ou via **violations de données** pour accéder aux services sans double authentification.
Vulnérabilités IDOR	Exploitations dans le périmètre ministériel, parfois combinées pour l'**exfiltration massive**. Défauts de développement : contrôle des autorisations absent, **injections SQL**, fichiers exposés.
Authentification faible	L'absence de **MFA** ou l'usage d'un second facteur faible (ex: **courriel**) permet l'accès via un mot de passe faible ou une fuite.
Sous-traitance	Risque de **compromission par rebond** : la compromission d'un prestataire entraîne le vol de données ministérielles dans ses infrastructures.

Synthèse des incidents par système ou entité

Notion	À retenir
Éducation nationale	Depuis **juillet 2026** : incidents sur **plus d'une dizaine d'académies**, latéralisations vers services nationaux déconcentrés et exfiltrations.
GAIA	Fin **juillet 2026** : intrusion et exfiltration potentielle de **4,35 millions d'enseignants** (identité, affectation, grade, formation, indemnités).
SIECLE	Revendication du **17 août 2026** : exfiltration données enseignants/élèves et base élèves de l'**académie de Créteil** (**1 million** d'élèves, responsables, enseignants).
Tchap	**19 août 2026** : compromission compte agent, accès salons (**DGFiP**, **cadastre**) et exfiltration conversations.
SNU	**7 septembre 2026** : faille **IDOR** du portail, **275 000 utilisateurs** exposés.
AEFE	**12 août 2026** : violation via compte compromis, accès annuaire interne et extraction données de **plus de 300 000 personnes**.

Synthèse des incidents des ministères économiques et financiers

Notion	À retenir
Bloctel	Violation **7 août 2026** (compte pro) ; ~**600 000** numéros inscrits identifiables par différence. Fermeture définitive **11 août 2026**.
TRACFIN	Compromission d'un sous-traitant (fin juin à mi-juillet 2026). **136** assujettis concernés (identité, contact, **213** demandes d'assistance). **Aucune** donnée de déclaration de soupçon exposée.
La DGDDI	**21 août 2026** : **3** comptes de messagerie + serveur d'échange compromis ; nouvelle authentification, accès courriel internet retiré.
La DGFiP	Exfiltration **353 000** particuliers, **252 000** pros (12-13 août 2026). Serveur cadastral : **2 millions** données (**434 000** usagers). Tentatives **PIGP** via **infostealers**.

Synthèse des incidents par sous-partie

Notion	À retenir
Organisation réponse	ANSSI sur **Bureau numérique** (investigations/remédiation) ; **prestataire** pour les autres directions. **Plan de remédiation** en déploiement.
Bureau numérique	Compromission de **> 300 comptes** (application `BNUM`) le **25 août 2026**. Exfiltration messagerie/fichiers. **MFA** activé.
OISO	Énumération des données personnelles de **22 000** agents et organismes agréés via un compte d'**organisme privé**. Portail isolé, corrigé, mots de passe réinitialisés.
Zéro Logement Vacant	Vol de données (**48 millions** de propriétaires) le **28 août 2026** via instance `Metabase`. Base isolée, service coupé.
Autres applications	Incidents en cours (**Signal Logement**, **Bureau des courriers**) ; exfiltrations sur `Qualicharge` (**102 000** sessions de recharge) et `Docurba`.

Synthèse des incidents Metabase par entité

Notion	À retenir
Laboratoire d'innovation ANSSI	**118 comptes** compromis (une **trentaine** externes) : identifiants, courriels, MDP hachés. Mise à jour, MDP renouvelés, comptes inactifs **> 3 mois** désactivés.
La DINUM	Instances **ProConnect** et **Nuage-Public** compromises (métadonnées, historiques anonymisés). Correction, secrets réinitialisés.
France VAE (Travail)	**8 août 2026** via Metabase : exfiltration de **toutes les données utilisateurs**. Information, mise à jour, MDP renouvelés.
Préférence Formation (Agriculture)	Revendication **début septembre 2026** : **5 265 personnes** potentiellement concernées.

Pièges et confusions

⚠ Confondre la date de demande du Premier ministre (1er septembre 2026) avec le début du comptage des violations (1er août 2026).

⚠ Croire qu'un second facteur par courriel est une méthode d'authentification forte.

⚠ Confondre l'acronyme usuel de l'IDOR (Insecure Direct Object Reference) avec le développement du document (Indirect Object Reference).

⚠ Penser que les chiffres du document sont exhaustifs alors qu'il s'agit d'un point de situation évolutif.

Sigles et définitions

REACTIV	REponse et ACTion Interministérielle face aux Violations de données.
Exfiltration	Vol de données copiées hors du système d'information de la victime.
Infostealer	Programme destiné à voler des informations sensibles comme des identifiants.
CVE	Identifiant public et unique d'une vulnérabilité informatique.
Compromission par rebond	Attaque via un prestataire ou un sous-traitant de la chaîne d'approvisionnement.
Latéralisation	Déplacement d'un attaquant d'un système compromis vers d'autres systèmes du même réseau.
Marqueurs de compromission	Indices techniques permettant de détecter une intrusion.
PASSI	Prestataire d'audit de la sécurité des systèmes d'information qualifié par l'ANSSI.

Auto-test

1. Quelle est la référence du point de situation de l'ANSSI ?
2. Combien de violations ont été portées à la connaissance de l'ANSSI depuis le 1er août 2026 ?
3. Quelle application a été compromise par une faille IDOR exposant 275 000 utilisateurs le 7 septembre 2026 ?
4. Quel outil de visualisation de bases de données est à l'origine de la vulnérabilité CVE-2026-72898 ?
5. Quelle messagerie instantanée sécurisée de l'État a subi une compromission de compte agent le 19 août 2026 ?

Réponses : **1.** CERTFR-2026-CTI-006 · **2.** 99 · **3.** SNU · **4.** Metabase · **5.** Tchap

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.